

Progettazione di un Sistema di Voto Elettronico Sicuro

Premio “Tesi dell’Anno” dell’Ateneo — un protocollo crittografico tra segretezza, verificabilità ed efficienza

Candidati Errico Gioia · Raffaele Cutolo

Docente Prof. Carlo Mazzocca A.A. 2025/2026

Agenda

1

WP1

Modello

Attori onesti, threat model e proprietà di sicurezza

2

WP2

Soluzione

Il protocollo in 4 fasi e gli strumenti crittografici

3

WP3

Analisi

Esperimenti formali, riduzioni e rischi residui

4

WP4

Implementazione

Architettura, prestazioni e demo del prototipo

Chiusura con sintesi delle garanzie, rischi residui ed estensioni future.

Il paradosso dell'e-voting

Due requisiti in tensione strutturale

- **Trasparenza del conteggio**

il risultato deve essere pubblicamente verificabile da chiunque

- **Segretezza della preferenza**

nessuno deve poter associare elettore e voto

Un sistema black-box dà privacy perfetta ma nessuna verifica; uno totalmente trasparente distrugge l'anonimato. Servono compromessi consapevoli.

Caso d'uso

Premio “Tesi dell'Anno”

- Eletto dalla comunità accademica (studenti + docenti)
- Contesto sociale denso: candidati = colleghi e conoscenti
- Pressione informale e compravendita del voto concrete
- Deve girare su un comune smartphone o PC

→ **Segretezza e resistenza alla coercizione sono qui particolarmente critiche.**

Scelte progettuali di base

Lista chiusa

Preferenza per una singola tesi da un insieme finito e predefinito di opzioni, più scheda bianca legittima.

Spazio voti piccolo

Un insieme di voti finito abilita tecniche più efficienti rispetto alla preferenza nominale libera.

1 elettore = 1 voto

Approccio egualitario: niente voto pesato, che richiederebbe protocolli troppo costosi.

Efficienza fin da WP1

Vincolo progettuale, non solo metrica finale: utilizzabile da dispositivo consumer.

Attori onesti e separazione dei ruoli



Assunzione cardine. Lo pseudoanonimato regge se IdP e Autorità Elettorale non si accordano: ciascuno possiede solo metà dell'informazione. Il rischio di collusione è dichiarato come limite strutturale del modello.

Modello di minaccia

Matrice avversari × proprietà — × compromissione diretta · ~ rischio parziale

Avversario	Autent.	Unicità	Segret.	Integr.	V. ind.	V. univ.	Dispon.	Irrev.
IdP disonesto	~	×						
AE disonesto			~	×	×	×		
Collusione IdP + AE			×					
Elettore malintenz.		×			~			×
Eavesdropper / MITM			~	×		×		
Avversario DoS							×	

Lettura. La collusione è l'unica minaccia che colpisce la segretezza in modo diretto e irrimediabile. Il DoS è incluso per completezza ma fuori dal perimetro crittografico del corso.

Proprietà da preservare e tensioni

Proprietà di sicurezza

- **Autenticità** — solo aventi diritto autenticati votano
- **Unicità** — al più un voto valido per elettore
- **Segretezza** — identità mai associabile alla preferenza
- **Integrità** — voti non alterabili né sopprimibili
- **Verif. individuale** — ogni elettore verifica il proprio voto
- **Verif. universale** — chiunque verifica il risultato

Compromessi dichiarati

Segretezza ↔ Unicità

tracciare la partecipazione senza vedere il voto → separazione IdP/AE

Segretezza ↔ Verif. individuale

il riferimento alla propria scheda non deve violare l'anonimato

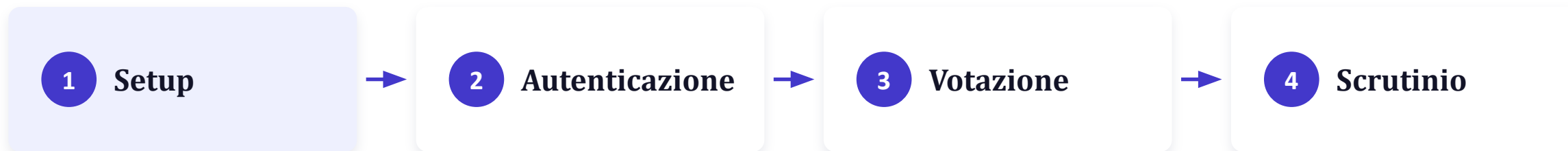
Verif. individuale ↔ Coercizione

la receipt-freeness non è garantita: scelta esplicita

Trasparenza ↔ Fiducia residua

non è trustless: si fida della non collusione

Panoramica del protocollo



Principio operativo: l'IdP autentica ma non vede il voto; l'AE registra il voto cifrato ma non conosce l'identità. Il ponte è un token = nonce casuale firmato.

STRUMENTI CRITTOGRAFICI

RSA-OAEP

cifratura della scheda (CCA-sicura)

Firme RSA / PSS

autenticità e non ripudio dei messaggi

SHA-256

ricevute e integrità delle schede

TLS

canale sicuro tra le parti

PKI X.509

distribuzione autenticata delle chiavi

Merkle Tree

bulletin board append-only verificabile

Bulletin Board + Merkle Tree

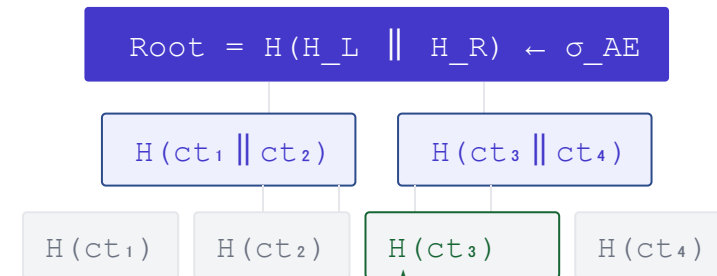
BULLETIN BOARD APPEND-ONLY

- Solo operazioni di aggiunta — mai rimozione o modifica
- Ogni voce: $(ct, \text{timestamp}, H(ct))$
- Timestamp a grana grossa (ora) → chiude canale di correlazione temporale
- Unica eccezione aggiornabile: CRL

$\sigma_{\text{root}} = \text{Sign}_{sk_{AE}}(H(\text{MerkleRoot} \parallel ts))$

Firmata ad ogni inserimento → chiunque verifica

STRUTTURA MERKLE TREE



L'elettore verifica ct_3 con un solo percorso π_{ct} (Merkle proof)

Setup e distribuzione delle chiavi

CA dedicata

Una Certification Authority creata per l'elezione emette i certificati X.509 delle entità; la chiave skCA va offline dopo il setup.

→ *ancora di fiducia*

CRL + hard-fail

Lista di revoca firmata: se un certificato è revocato o la CRL è irraggiungibile, il certificato è rifiutato.

→ *no certificati revocati*

Separazione chiavi AE

Coppia di firma (ricevute, root) e coppia di cifratura (schede) distinte; dkAE resta offline fino allo scrutinio.

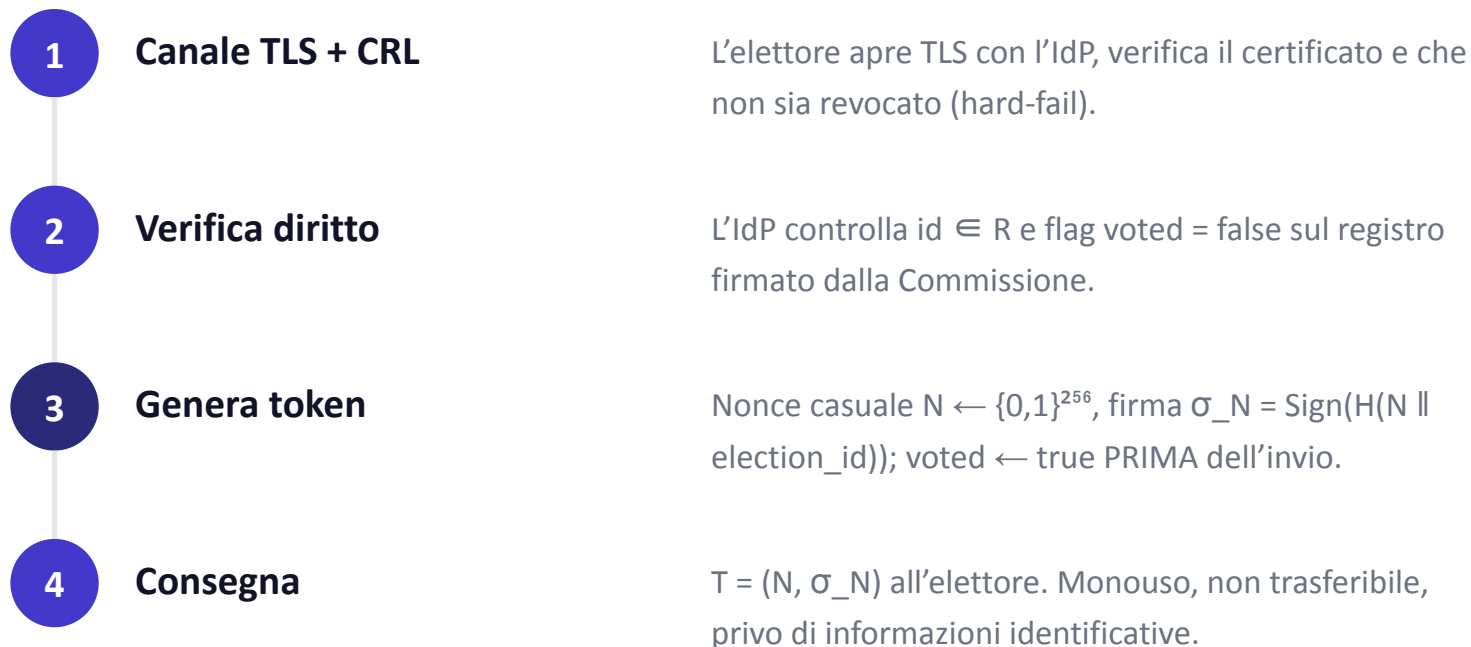
→ *principio di minimo privilegio*

Lista candidati firmata

La Commissione firma $C = \{c_1 \dots c_n, c_\perp\}$ e N_{elig} ; pubblica sul bulletin board prima dell'apertura.

→ *autenticità delle opzioni*

Autenticazione: il token anonimo



Perché funziona

Il nonce è puramente casuale: l'AE può verificarne la firma con pk_IdP ma non risalire all'identità.

Rischio residuo. IdP e AE colludenti fanno un join sul nonce $N \rightarrow (identità, voto)$. Mitigabile con blind signature (estensione futura).

Ordine delle operazioni ($voted \leftarrow true$ prima dell'invio) $\rightarrow$ niente doppio token in race condition.

Votazione: scheda cifrata e ricevuta

Lato elettore

1 Prepara la scheda

sceglie cv , genera nonce r , $m = cv \parallel r$

2 Cifra con RSA-OAEP

$ct = \text{Enc}(ek_{AE}, m)$ — non deterministico

3 Trasmette

$M_{\text{vote}} = (N, \sigma_N, ct)$ su TLS — nessuna identità

4 Conserva il fascicolo

$F = (cv, r, ct, \rho)$ per la verifica

Lato Autorità Elettorale

● Verifica il token

firma σ_N valida e nonce $N \notin U$ (non già speso)

● Registra sul bulletin board

voce append-only + aggiorna il Merkle tree e firma la root

● Emette la ricevuta

$\rho = \text{Sign}(H(ct \parallel \text{timestamp} \parallel \text{election_id}))$

Timestamp a grana oraria: chiude il canale di correlazione temporale identità ↔ scheda.

Scrutinio e pubblicazione



Output ufficiale pubblicato:

(T , σ_{result} , D , $\text{MerkleRoot}_{\text{final}}$, σ_{close})

Controllo di trasparenza: $|BB| = |D| + |I|$ — le schede totali coincidono con valide + invalide.

$c \perp$ (scheda bianca) conteggiata ma esclusa dalla vittoria.

Verifica individuale e universale

Individuale

l'elettore, con il solo fascicolo F e i dati pubblici

- Verifica l'autenticità della ricevuta p (firma AE)
- Verifica l'inclusione di ct via Merkle proof
- Trova $(ct, cv) \in D$ e controlla cv = preferenza espressa

Nessuna collaborazione di terzi richiesta. Algoritmo pubblico.

Universale

chiunque, solo dai dati pubblici del bulletin board

- Verifica σ_{close} e ricalcola la Merkle root finale
- Consistenza $|BB| = |D| + |I|$
- Bilancio dei voti $m \leq K \leq N_{elig}$
- Ricalcola il conteggio $T' = T$ e verifica σ_{result}

Il bilancio $m \leq K \leq N_{elig}$ intercetta il ballot stuffing.

Metodologia: esperimenti e riduzioni

Ogni proprietà è un gioco $\text{Esp}_{\{A, \Pi\}}(n)$ tra sfidante e avversario PPT; la garanzia è dimostrata per riduzione alle primitive del corso.

Sig-forge

infalsificabilità
delle firme RSA

Autenticità · Unicità · Integrità

PubK-cca

CCA-sicurezza
di RSA-OAEP

Segretezza della scheda

Hash-coll

resistenza alle
collisioni di SHA-256

Integrità · Verificabilità

Prevenzione vs. rilevazione

Diverse proprietà non sono garantite in senso preventivo (rendere l'attacco impossibile) ma rilevativo (renderlo sempre individuabile). **L'AE non è resa incapace di tentare la manomissione dell'urna — ma ogni tentativo è pubblicamente rilevabile e rende l'elezione respingibile.**

Autenticità + Unicità

E1, E3 — VOTE-FORGE

Forgery + Replay

PRESERVATA

A tenta di produrre (N^*, σ^*) valido senza sk_IdP

Vincere Vote-Forge $\rightarrow$ produrre σ^* su $N^* \notin Q \rightarrow \equiv$ contraffazione
Sig-forged

E1 ✓ — Firma arbitraria $\rightarrow$ respinto

E3 ✓ — Replay election_id 2025 su 2026 $\rightarrow$ respinto (binding)

$\Pr[\text{Vote-Forge}] \leq \Pr[\text{Sig-forged}] \leq \text{negl}(n)$

E2 — VOTE-UNIQUE

Doppio Voto

PRESERVATA

A vuole registrare due schede distinte per la stessa identità

2 token diversi $\rightarrow$ richiede forgery su sk_IdP Riuso N con ct
diverso $\rightarrow$ rifiutato: $N \in U$ Re-invio identico $\rightarrow$ idempotente

✓ 1° voto C001 accettato

✓ 2° voto stesso token $\rightarrow$ respinto ($N \in U$)

✓ Re-invio identico $\rightarrow$ idempotente

$\Pr[\text{Vote-Unique}] \leq \text{negl}(n)$

Vote-Anon: Segretezza

E7 — NON-DETERMINISMO OAEP

Riservatezza della Scheda

PRESERVATA

Due cifrature dello stesso voto C001 → ciphertext sempre distinti → nessuna correlazione

Vincere Vote-Anon (riservatezza) → distinguere ct_0 da ct_1 → $\equiv$
distinguitore PubK_{cca} RSA-OAEP

Riduzione → PubK_{cca} (RSA-OAEP)

$\Pr \leq \frac{1}{2} + \text{negl}(n)$

E8 — COLLUSIONE IdP + AE

Linkage di Identità

LIMITE ⚠

IdP: (identità, N) · AE: (N, voto) → JOIN su N

`info_IdP JOIN info_AE ON N → (identità, voto) per ogni
elettore → 5/5 de-anonimizzati (100%)`

$\Pr[\text{Vote-Anon}] = 1$

Soluzione: **Blind Signatures** (estensione futura)

Tally-Forge: Integrità

E4 — MANOMISSIONE

Alterazione Scheda

PRESERVATA

AE sostituisce ct con ct' nella voce del BB

```
Root ricalcolata ≠ Root firmata →  
manomissione rilevata
```

Riduzione → Hash-coll SHA-256

E5 — SOPPRESSIONE

Rimozione Voto

PRESERVATA

AE rimuove una scheda e ricostruisce l'albero
senza di essa

```
Merkle proof di ct fallisce rispetto a  
Root_final
```

Rilevato dalla vittima: verifica individuale

E6 — BALLOT STUFFING

Iniezione Schede

PRESERVATA

N_elig=100, K=80. AE inietta 5 schede false →
m=85

```
m=85 > K=80 → bilancio violato →  
respinto
```

Riduzione → Sig-forge (bilancio firmato)

GARANZIA | $\Pr[\text{Tally-Forge}] \leq \text{negl}(n)$ sotto BB non-equivocante, Hash-coll e Sig-forge

Receipt-Freeness

LA TENSIONE STRUTTURALE

Verificabilità Individuale ✓

$F = (cv, r, ct, \rho) \rightarrow$ l'elettore verifica che il suo voto sia incluso e conteggiato correttamente

↕ in tensione con

Receipt-Freeness ✗ LIMITE

Lo stesso F permette di provare la preferenza a un coercitore tramite D pubblico

ESPERIMENTO E9

Coercitore riceve $F = (cv, r, ct, \rho)$:

1. Verifica $\rho \rightarrow ct$ autentico ✓
2. Trova ct nel Bulletin Board ✓
3. Legge in D : $ct \rightarrow C002$ ✓

$\Pr[\text{Receipt}] = 1$

Prova di preferenza riuscita al 100%

"Nessuno scopre la preferenza contro la volontà dell'elettore. Manca solo l'impossibilità che la riveli volontariamente."

Esiti degli esperimenti

	Proprietà	Avversario	Riconduzione	Esito
E1	Autenticità	Elettore (forgery)	Sig-forge	Preservata
E3	Autenticità (freshness)	Elettore (replay)	Sig-forge + election_id	Preservata
E2	Unicità	Doppio voto	Sig-forge + insieme U	Preservata
E7	Segretezza	Eavesdropper	PubK-cca (RSA-OAEP)	Preservata
E8	Segretezza	Collusione IdP + AE	Assunzione non collusione	Limite
E4	Integrità	AE (manomissione)	Hash-coll	Preservata
E5	Integr. / V. ind.	AE (soppressione)	Hash-coll	Preservata
E6	Verif. universale	AE (riempimento)	Sig-forge (bilancio)	Preservata
E9	Receipt-freeness	Coercitore	Limite strutturale	Limite

Due limiti, non difetti. E8 (collusione) ed E9 (coercizione) sono vinti con probabilità 1: conferme formali dei rischi residui già dichiarati nel WP1.

Rischi residui ed estensioni future

Rischi residui (per criticità)

- 1 Collusione IdP + AE — unica minaccia diretta alla segretezza
- 2 Correttezza della decifrazione — D coerente, ma non provata
- 3 Equivocazione del bulletin board centralizzato
- 4 Coercizione — assenza di receipt-freeness (accettata)
- 5 Segretezza delle chiavi sk_{IdP} , sk_{AE} , dk_{AE}

Estensioni future

Blind signatures — eliminano il linkage da collusione

Schema a soglia (t,n) — nessun singolo punto di decifrazione

Prove ZKP di decifrazione — rendono D verificabile senza fiducia

Bulletin board su DLT — elimina l'equivocazione del registro

MFA / FIDO2–WebAuthn — rafforza l'anello umano dell'autenticità

Architettura del prototipo

Ambiente

- **Python 3.13**

libreria cryptography + hashlib

- **Simulazione in-process**

ogni entità è una classe con le proprie chiavi

- **PKI X.509 reale**

certificati e CRL autentici, non simulati

- **RSA-OAEP + PSS**

PSS calcola l'hash → equivale a $\text{Sign}(H(m))$

- **GUI Tkinter**

solo presentazione, zero logica crittografica

Un modulo per attore del modello

<code>crypto_utils</code>	RSA-OAEP, firme, SHA-256, Merkle
<code>pki</code>	CA, X.509, CRL, verifica hard-fail
<code>bulletin_board</code>	registro append-only + Merkle tree
<code>commission</code>	lista candidati, registro, N_elig
<code>idp</code>	autenticazione, token firmato
<code>authority</code>	raccolta voti, ricevute, scrutinio
<code>voter</code>	votazione, verifica individuale
<code>verifier</code>	verifica universale

Prestazioni

~2 ms

per voto / elettore

costante al crescere dell'urna

544 B

messaggio di voto

dimensione fissa e compatta

< 0,6 ms

verifica universale

anche con 200 elettori

Andamento al variare dell'elettorato

N elettori	Voto / elett.	Scrutinio	Verif. ind.	Verif. univ.
10	1,94 ms	11 ms	0,12 ms	0,32 ms
50	1,89 ms	43 ms	0,14 ms	0,36 ms
100	1,88 ms	85 ms	0,15 ms	0,41 ms
200	1,93 ms	169 ms	0,20 ms	0,52 ms

Lettura

Voto e verifica restano sostanzialmente costanti; scrutinio lineare. L'unica operazione costosa — generare le chiavi RSA-2048 — avviene una sola volta in setup. Sistema adeguato ai vincoli di efficienza del WP1.

DEMO DAL VIVO

Prototipo del protocollo in azione



CONCLUSIONI

Un compromesso coerente e difendibile

Garantite in pieno

- Autenticità
- Unicità
- Integrità (in senso rilevativo)
- Irrevocabilità

Parziali, con limite circoscritto

- Segretezza — salvo collusione IdP/AE
- Verif. individuale — salvo prova di decifrazione
- Verif. universale — salvo prova di decifrazione
- Disponibilità — fuori perimetro (DoS)

I limiti non sono difetti occulti, ma scelte esplicite e circoscritte da assunzioni chiare — per ciascuna è identificata la strada di superamento.

Grazie per l'attenzione.

Impersonificazione degli astenuti

La catena di bilancio intercetta

$$m \leq K \leq N_{\text{elig}}$$

- **Stuffing dell'AE** — schede senza token valido $\rightarrow m > K$
- **Sovraemissione dell'IdP** — $K > N_{\text{elig}}$ (token oltre gli aventi diritto)

Entrambi gli squilibri sono garanzie rilevative: emergono pubblicamente in verifica universale.

Non intercetta: il voto al posto degli astenuti

LIMITE

- IdP disonesto che vota per gli astenuti restando sotto N_{elig} $\rightarrow m$ e K crescono insieme: nessuno squilibrio emerge.
- Attacco di un IdP isolato $\rightarrow$ non richiede collusione con l'AE (diverso dal limite E8).
- Strutturalmente non rilevabile: gli astenuti non hanno ricevuta né fascicolo F e non fanno verifica individuale.

Difesa nel modello

L'IdP è dichiarato **fidato sull'eleggibilità**: la difesa è l'assunzione di fiducia, senza appiglio crittografico.

Fix completo

Eligibility verifiability — fuori dal perimetro del corso, indicata come estensione futura.

 **Le blind signature NON risolvono questo:** risolvono la collusione (E8), non l'impersonificazione degli astenuti. Due limiti distinti, due soluzioni distinte.

Segretezza sotto AE disonesta isolata

Il claim “serve la collusione” regge a livello formale

La de-anonimizzazione completa (identità anagrafica ↔ voto, 100% degli elettori) richiede la collusione IdP + AE — esperimento E8.

dk_AE centralizzata e online

LEVA 1

Durante l'elezione l'AE può decifrare le schede prima della chiusura → erosione della segretezza temporale.

Metadati del proprio endpoint TLS

LEVA 2

IP e istante della connessione: l'AE è il destinatario del canale, quindi li vede. TLS protegge dagli altri, non dall'AE.

Effetto combinato

L'AE lega (IP, istante, voto) in tempo reale. In un ateneo l'IP è spesso identificante. L'identità anagrafica formale resta protetta dalla separazione dei ruoli.

 **Distinto dal timestamp a grana oraria:** quella mitigazione chiude il canale di correlazione dell'IdP (orario di autenticazione vs. orario pubblico sul bulletin board), non quello dell'AE, che vede l'orario reale e preciso sul proprio canale.

Fix Schema a soglia (t,n) su dk_AE — già tra le estensioni future → toglie all'AE la capacità di decifrare da sola.